

SECURITY OPERATIONS



HolySec

PENTEST MANAGEMENT PLATFORM

Die professionelle Plattform für Penetration-Testing-Teams —
Clients, Schwachstellen, Engagements und Reports in einem System.

Version 1.0

Erstellt von Leif Balthasar — Founder & Senior
Pentester

Stand Mai 2026

Inhaltsverzeichnis

1	Was ist HolySec?	3
	Warum HolySec?	
	Für wen ist es gemacht?	
2	Einstieg & Anmeldung	4
	Login & Rollen	
	Oberfläche im Überblick	
3	Dashboard	5
	KPI-Kacheln	
	Charts & Visualisierungen	
4	Client-Verwaltung	6
	Client Radar	
	Client Manager	
	Client Map	
5	Schwachstellen (Findings)	8
	CVSS & Schweregrade	
	Workflow: Open → Remediation → Closed	
6	Engagements & Projekte	9
	Engagement-Typen	
	Gantt-Zeitstrahl	
	Team-Zuweisung	
7	Reports	10
	Report-Typen	
	Status-Workflow	
8	Team & Benutzerverwaltung	11
9	Audit Log	12
10	Einstellungen	12
11	Technische Architektur	13

KAPITEL 1

Was ist HolySec?

HolySec ist eine webbasierte Pentest-Management-Plattform, die speziell für professionelle Penetration-Testing-Teams entwickelt wurde. Sie bündelt alle Informationen rund um Clients, Schwachstellen, Projekte und Berichte in einer einzigen, übersichtlichen Oberfläche — und schafft damit die operative Grundlage für strukturierte, nachvollziehbare und skalierbare Sicherheitstests.

Warum HolySec?

Pentesting-Teams arbeiten heute oft mit einem Flickenteppich aus Tabellenkalkulationen, Ticketsystemen und losen Dokumenten. Das kostet Zeit, erzeugt Fehler und macht es schwer, den Überblick zu behalten. HolySec löst dieses Problem mit einem klaren, zentralen System:



Zentrales Dashboard

Alle KPIs auf einen Blick — aktive Clients, offene Kritikalitäten, geplante Tests.



Strukturierte Findings

CVSS-bewertete Schwachstellen mit CVE-Referenzen, Statusverfolgung und Remediation-Workflow.



Projekt-Management

Engagements mit Gantt-Zeitstrahl, Team-Zuweisung und Phasen-Tracking.



Report-Registry

Technical Reports, Executive Summaries und Remediation Plans — alle an einem Ort.



Client-Karte

Interaktive Geo-Karte aller Kunden mit Status und Engagement-Infos.



Audit Log

Vollständiges Aktivitätsprotokoll für Compliance und Nachvollziehbarkeit.

Für wen ist HolySec gemacht?

Zielgruppe	Nutzen
Pentest-Teams	Zentraler Arbeitsplatz für alle Projekte, Findings und Reports ohne Zettelwirtschaft
Senior Pentester	Übersicht über Teamauslastung, Projektphasen und kritische Schwachstellen
Administratoren	Vollzugriff inkl. Benutzerverwaltung, Audit Log und Systemkonfiguration
Security-Boutiquen	Professionelles Tool, das mit dem Team wächst — ohne teure Enterprise-Lizenzen

KAPITEL 2

Einstieg & Anmeldung

Login & Rollen

HolySec verwendet ein rollenbasiertes Zugriffsmodell. Beim Start öffnet sich ein Cyber-Login-Bildschirm. Geben Sie Ihre E-Mail-Adresse und Ihr Passwort ein — danach landen Sie direkt auf dem Dashboard.



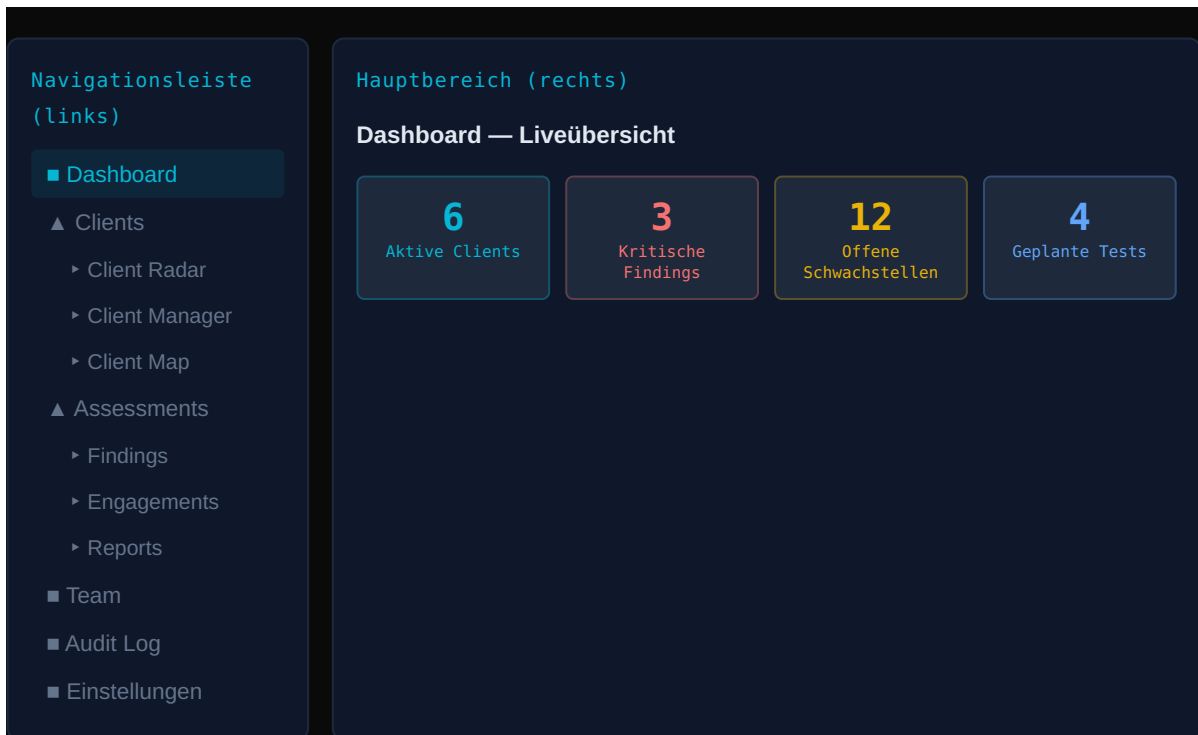
Erststart: Beim ersten Start des Systems werden die konfigurierten Standardnutzer automatisch geladen. Der Administrator richtet weitere Accounts über die Team-Verwaltung ein.

HolySec kennt drei Rollen mit unterschiedlichen Zugriffsrechten:

Rolle	Sichtbare Bereiche	Besonderheiten
Admin	Alle Bereiche inkl. Audit Log & Eng. Groups	Vollzugriff, Benutzerverwaltung, Systemeinstellungen
Senior Pentester	Dashboard, Clients, Assessments, Team, Eng. Groups	Kann Engagements gruppieren, sieht eigene + zugewiesene Projekte
Pentester	Dashboard, eigene Clients & Engagements, Reports	Eingeschränkte Sicht — nur zugewiesene Projekte sichtbar

Oberfläche im Überblick

Nach dem Login sehen Sie zwei Hauptbereiche:



Die Navigationsliste auf der linken Seite lässt sich mit dem Pfeilbutton ein- und ausklappen, um mehr Platz für den Arbeitsbereich zu gewinnen. Ein Klick auf einen Menüpunkt lädt den jeweiligen Bereich sofort — ohne Seitenneuladen.

KAPITEL 3

Dashboard

Das Dashboard ist Ihre Schaltzentrale. Es gibt auf einen Blick Auskunft über den aktuellen Sicherheitsstatus Ihrer gesamten Client-Basis und zeigt wichtige Trends in Form von Diagrammen.

KPI-Kacheln

Die vier Kennzahlen oben auf dem Dashboard sind Ihre wichtigsten Echtzeitindikatoren:

Kachel	Was sie zeigt	Handlungsbedarf
Aktive Clients	Anzahl Clients mit Status "Active" — laufende Verträge und aktive Engagements	Keine — Überblicksinformation
Offene Kritikalitäten	CVSS ≥ 9.0 Findings mit Status "Open" quer über alle Clients	Sofortige Maßnahmen erforderlich
Offene Findings	Alle Schwachstellen mit Status "Open" — alle Schweregrade	Regelmäßig prüfen und priorisieren
Geplante Tests	Engagements mit Status "Planned" — noch nicht gestartete Pentests	Ressourcen frühzeitig einplanen



Tipp: Jede Kachel hat ein kleines Info-Symbol (i). Fahren Sie mit der Maus darüber, um eine detaillierte Erklärung der Kennzahl zu erhalten — ideal für neue Teammitglieder.

Charts & Visualisierungen

Unterhalb der KPI-Kacheln befinden sich drei interaktive Diagramme:



Engagements pro Monat

Balkendiagramm der abgeschlossenen und geplanten Projekte über die letzten 12 Monate. Ideal für



Findings nach Schweregrad

Kreisdiagramm der Schwachstellenverteilung (CRITICAL / HIGH / MEDIUM / LOW). Zeigt auf einen Blick, ob Ihr



CVSS-Score-Verteilung

Häufigkeitsverteilung aller CVSS-Scores in Intervallen (0–10). Hilft zu erkennen, ob sich Schwachstellen im

Kapazitätsplanung und
saisonale
Auslastungsanalyse.

Team hauptsächlich mit
hochkritischen oder
mittelschweren
Befunden konfrontiert ist.

oberen oder unteren
Scoring-Bereich
konzentrieren.

Am unteren Ende des Dashboards finden Sie die **Neuesten kritischen Findings** — sortiert nach Datum, mit aktuellem Behebungsstatus. So verpassen Sie keine frischen CRITICAL-Befunde.

KAPITEL 4

Client-Verwaltung

Die Client-Verwaltung ist das Herzstück von HolySec. Hier verwalten Sie alle Kundenbeziehungen, sehen deren Sicherheitsstatus und planen die nächsten Schritte.

Client Radar

Der Client Radar bietet eine schnelle Statusübersicht aller Kunden, gefiltert nach wichtigen Dimensionen:

Filter-Kachel	Bedeutung
Active	Laufender Vertrag, Engagements aktiv oder aktiv geplant
On Hold	Pentest-Prozess vorübergehend pausiert (z.B. Freeze-Phase beim Kunden)
Critical	CVSS $\geq$ 9.0 Findings offen — höchste Handlungspriorität
Due Soon	Nächster Pentest in $\leq$ 30 Tagen — Vorbereitung & Ressourcenplanung erforderlich

Jede Client-Karte im Radar zeigt: Name, Branche, Status, Scope-Typ, Kritikalität, nächsten Testtermin sowie die Anzahl offener Findings. Ein Klick auf die Karte öffnet das vollständige Client-Profil.

Client Manager

Der Client Manager ist die vollständige Verwaltungsansicht aller Kunden. Pro Client sehen Sie:

Kontakt & Vertrag	Scope-Definition	Sicherheitsstatus
• Name, E-Mail, Telefon des Ansprechpartners • Vertragslaufzeit (Start- und Enddatum)	• IP-Bereiche & Subnetze • Domains & Subdomains • Explizite Ausschlüsse (Out-of-Scope)	• Offene Findings (nach Schweregrad) • Behobene Findings • Verknüpfte Engagements



Budget-Warnung: Sobald mehr als 85% der Vertragsstunden verbraucht sind, wird das Budgetfeld rot markiert. Das ist das Signal, eine Vertragsverlängerung mit dem Kunden zu besprechen.

Client Map

Die Client Map zeigt alle Kunden als Marker auf einer interaktiven Karte (basierend auf OpenStreetMap via Leaflet). Jeder Marker ist nach Kritikalität eingefärbt:

Farbe	Kritikalität	Bedeutung
● Rot	CRITICAL	CVSS ≥ 9.0 Findings offen — sofortiger Handlungsbedarf
● Orange	HIGH	CVSS 7.0–8.9 — erhöhte Aufmerksamkeit erforderlich
● Gelb	MEDIUM	CVSS 4.0–6.9 — im regulären Remediation-Prozess
● Grün	LOW	CVSS < 4.0 — kein unmittelbarer Handlungsbedarf

Ein Klick auf einen Marker öffnet ein Popup mit Client-Name, Stadt, Status und der Anzahl offener Findings. Die Karte lässt sich zoomen, verschieben und vollständig mit der Maus bedienen.

KAPITEL 5

Schwachstellen (Findings)

Die Findings-Datenbank erfasst alle im Rahmen von Engagements entdeckten Schwachstellen. Sie ist das zentrale Wissensspeicher Ihrer Sicherheitsarbeit.

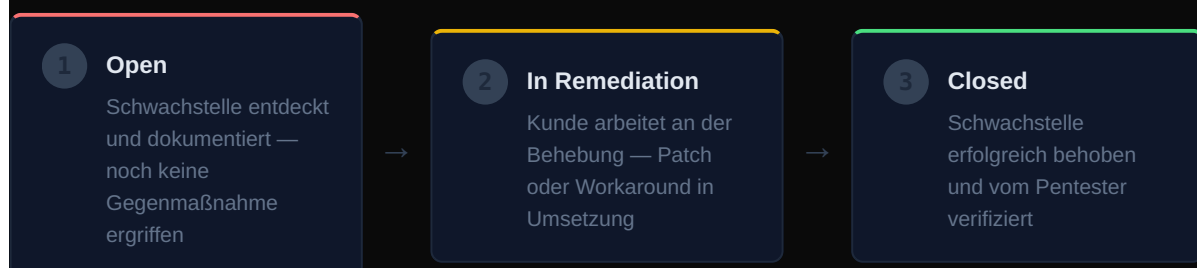
CVSS & Schweregrade

Jedes Finding wird nach dem **Common Vulnerability Scoring System (CVSS)** bewertet. Der Score reicht von 0.0 bis 10.0 und wird in vier Schweregrade eingeteilt:

Schweregrad	CVSS-Bereich	Beispiele	Reaktionszeit
CRITICAL	9.0 – 10.0	RCE, Log4Shell, SQL Injection, unauthentifzierter Admin-Zugriff	Sofort (0–24h)
HIGH	7.0 – 8.9	Privilege Escalation, SSRF, schwache Authentifizierung	Kurzfristig (1–7 Tage)
MEDIUM	4.0 – 6.9	XSS, veraltete TLS-Versionen, fehlende Security Headers	Mittelfristig (7–30 Tage)
LOW	0.0 – 3.9	Informationsoffenlegung, fehlende HSTS-Header	Langfristig (nächster Patch-Zyklus)

Workflow: Open → In Remediation → Closed

Jedes Finding durchläuft einen klar definierten Lifecycle:



Den Status wechseln Sie durch einen einfachen Klick auf den Status-Badge in der Findings-Liste — das System protokolliert die Änderung automatisch im Audit Log.



CVE-Referenzen: Wenn ein Finding auf eine bekannte CVE-Nummer zurückgeht, ist diese direkt verlinkt. So können Sie schnell auf die offiziellen Sicherheitshinweise des Herstellers zugreifen.

KAPITEL 6

Engagements & Projekte

Engagements sind die geplanten und laufenden Pentest-Projekte. HolySec verwaltet jeden Auftrag mit Zeitraum, Team, Phasen und aktuellem Status.

Engagement-Typen

Typ	Scope	Typische Dauer
Web	Webanwendungen, APIs, Login-Systeme, Admin-Panels	1–4 Wochen
Network	Interne Netzwerke, IP-Bereiche, Server-Infrastruktur	2–6 Wochen
Social Engineering	Phishing, Vishing, physischer Zugang	1–3 Wochen
Full Red Team	Vollständiger Angriff inkl. Phishing, Netzwerk, Eskalation, Exfiltration	4–12 Wochen

Gantt-Zeitstrahl

Der Gantt-View zeigt alle Engagements als horizontale Balken auf einem Zeitstrahl. Die Farbe entspricht dem Status:

- **Cyan — Planned:** Noch nicht gestartet, aber terminiert
- **Grün — Completed:** Erfolgreich abgeschlossen
- **Grau — On Hold:** Vorübergehend pausiert

Der Gantt-Zeitstrahl ist besonders hilfreich für die Ressourcenplanung: Überschneidungen mehrerer Engagements sind sofort sichtbar.

Team-Zuweisung

Über den Zuweisungs-Button (Pfeil-Icon) in der Engagement-Liste können Teammitglieder einem Projekt zugewiesen werden. Nicht-Admin-Nutzer sehen nach dem Login nur die

Engagements, denen sie zugewiesen sind — so bleibt die Übersicht klar und datenschutzkonform.

Engagement-Phasen

Jedes Engagement durchläuft standardisierte Phasen, die den professionellen Pentest-Prozess abbilden:



KAPITEL 7

Reports

Die Report-Registry verwaltet alle erstellten Berichte geordnet nach Client und Engagement. Sie ist der zentrale Archiv für Ihre gesamte Berichtsdocumentation.

Report-Typen

TR

Technical Report

Der vollständige technische Bericht für das IT-Team des Kunden. Enthält alle Findings mit CVSS-Scores, Proof-of-Concept-Beschreibungen, Screenshots und detaillierten Remediationsempfehlungen. Richtet sich an Sicherheitsverantwortliche und Entwickler.

ES

Executive Summary

Die Kurzfassung für das Management. Konzentriert sich auf Risikobewertung, Geschäftsauswirkungen und strategische Handlungsempfehlungen — ohne technische Details. Geeignet für Vorstände, Geschäftsführer und CISOs.

RP

Remediation Plan

Der strukturierte Maßnahmenplan nach Abschluss eines Engagements. Priorisiert alle Findings nach Dringlichkeit, schlägt konkrete Schritte vor und dient als Checkliste für den Verifikations-Pentest.

Status-Workflow

Reports durchlaufen ebenfalls einen klar definierten Status-Workflow. Der Status lässt sich per Klick in der Report-Liste weiterschalten:

1

Draft

Bericht in Erstellung —
noch nicht an den
Kunden übergeben



2

Delivered

Bericht dem Kunden
zugestellt — Feedback-
Phase läuft



3

Final

Abgeschlossener,
freigegebener Bericht
— archiviert

Team & Benutzerverwaltung

Im Team-Bereich sehen und verwalten Administratoren alle Mitglieder des Pentest-Teams. Hier werden Profile, Rollen und Fähigkeiten gepflegt.

Jedes Teammitglied-Profil enthält:

- **Name & Avatar** — mit farbiger Initialen-Kachel
- **Rolle** — Admin, Senior Pentester oder Pentester
- **Berufsbezeichnung** — z.B. "Web Security Analyst"
- **Skills** — z.B. Web, Network, OT/ICS, Cloud, Social Engineering
- **Status** — Active oder inaktiv
- **E-Mail-Adresse** — für Systemkommunikation

Neue Benutzer anlegen

Über den "+ Mitglied"-Button (Admin-Rolle erforderlich) können neue Teammitglieder mit ihren Zugangsdaten und der entsprechenden Rolle angelegt werden. Das System unterstützt unbegrenzt viele Nutzer.



Rollenkonzept: Die Rollenzuweisung steuert, welche Navigationsbereiche sichtbar sind und auf welche Daten zugegriffen werden kann. Eine nachträgliche Rollenänderung ist jederzeit möglich.

KAPITEL 9

Audit Log

Das Audit Log ist ausschließlich für Administratoren sichtbar und bietet ein vollständiges, unveränderliches Aktivitätsprotokoll aller Nutzeraktionen im System.

Folgende Ereignisse werden protokolliert:

Ereignistyp	Beispiel
Anmeldungen	Login/Logout mit IP-Adresse, Zeitstempel und Nutzernamen
Datenänderungen	Statuswechsel von Findings, Anlegen/Löschen von Clients
Engagement-Aktionen	Team-Zuweisung, Statusänderungen bei Projekten
Report-Aktionen	Download, Statuswechsel (Draft → Delivered → Final)
Benutzerverwaltung	Anlegen, Bearbeiten oder Deaktivieren von Accounts



Compliance-Relevanz: Das Audit Log ist essenziell für Nachweispflichten in regulierten Branchen (z.B. Finanz, Gesundheit, öffentlicher Sektor). Es dokumentiert lückenlos, wer wann was im System getan hat.

KAPITEL 10

Einstellungen

Im Einstellungsbereich können Nutzer ihr persönliches Erlebnis und Systemverhalten anpassen. Die Einstellungen sind in zwei Kategorien unterteilt:

Darstellung

Einstellung	Optionen	Beschreibung
Erscheinungsbild	Dark Mode / Light Mode	Schaltet die gesamte Oberfläche zwischen dem Cyber-Dark-Theme und einem hellen, kontrastreichen Layout um
Sprache	Deutsch / English	Setzt alle Navigationsbeschriftungen, Tooltips und Systemtexte in die gewählte Sprache — ohne Seitenneuladen

Konto

Im Kontobereich der Einstellungen können Nutzer ihr eigenes Passwort ändern. Administratoren haben zusätzlich Zugriff auf die Benutzerverwaltung und können Systempasswörter zurücksetzen.

KAPITEL 11

Technische Architektur

HolySec ist so gebaut, dass es einfach zu betreiben ist — kein komplexes Setup, keine externe Cloud-Abhängigkeit. Alles läuft lokal auf Ihrer Infrastruktur.

Komponente	Technologie	Funktion
Frontend	React + Vite + Tailwind CSS	Single-Page-Application — reaktive UI ohne Seitenneuladen
Charts	Recharts	Interaktive Diagramme (Balken, Kreis, Linien)
Karte	Leaflet + OpenStreetMap	Interaktive Client-Weltkarte ohne externe API-Kosten
Backend	Node.js + Express	Leichtgewichtiger REST-API-Server
Datenbank	SQLite (better-sqlite3)	Dateibasierte Datenbank — kein separater DB-Server notwendig
Schriftart	JetBrains Mono	Professionelle Monospace-Schrift im Cyber-Stil

Datenpersistenz

Alle Daten werden über eine einfache Key-Value-API im Backend gespeichert. Die SQLite-Datei `holysec.db` enthält den gesamten Systemzustand und kann einfach gesichert werden:

Backup der Datenbank

```
# Einfaches Backup – einmalig oder als Cronjob
cp /pfad/zu/holySec/backend/holysec.db /backup/holysec_$(date +%Y%m%d).db
```

Deployment

HolySec kann auf jedem Linux-System mit Node.js gestartet werden. Das mitgelieferte Start-Skript übernimmt Build und Start in einem Schritt:

Start des Systems

```
# Erstmaliger Start (Build + Server)
cd holySec
bash start.sh

# Das System ist danach erreichbar unter:
# http://localhost:5173/holySec/
# http://<IP-Adresse>:5173/holySec/ (Netzwerkzugriff)
```



Netzwerkzugriff: Der Server bindet auf `0.0.0.0` — das bedeutet, das System ist für alle Geräte im selben Netzwerk erreichbar. Für produktiven Einsatz empfiehlt sich ein Reverse-Proxy (z.B. Nginx) mit HTTPS und Firewall-Regeln.

KAPITEL 12

Schnellstart-Anleitung

Mit diesen Schritten sind Sie in wenigen Minuten produktiv:

1 System starten

Führen Sie `bash start.sh` im HolySec-Verzeichnis aus. Der Server startet automatisch und zeigt die Netzwerk-URL an.

2 Anmelden

Öffnen Sie die angezeigte URL im Browser. Melden Sie sich mit Ihren Zugangsdaten an. Als Admin haben Sie sofort vollen Zugriff.

3 Team einrichten

Navigieren Sie zu **Team** und legen Sie alle Teammitglieder mit ihren Rollen und Fähigkeiten an.

4 Ersten Client anlegen

Öffnen Sie den **Client Manager** und tragen Sie Ihren ersten Kunden ein — mit Kontaktdaten, Vertragsinfos und Scope-Definition.

5 Engagement erstellen

Gehen Sie zu **Engagements** und legen Sie das erste Pentest-Projekt an — mit Zeitraum, Typ und Team-Zuweisung.

6 Findings dokumentieren

Erfassen Sie Schwachstellen über den **Findings**-Bereich mit CVSS-Score, CVE-Referenz und Remediationsempfehlung.

7 Report verwalten

Erstellen Sie nach Abschluss einen Eintrag in der **Report-Registry** und tracken Sie den Status (Draft → Delivered → Final).

8 Dashboard beobachten

Das **Dashboard** aktualisiert sich automatisch. Alle KPIs und Charts spiegeln den aktuellen Systemzustand wider.



HolySec

PENTEST MANAGEMENT PLATFORM

Strukturiert testen. Klar dokumentieren. Sicher wachsen.

Entwickelt von Leif Balthasar – Founder & Senior Pentester